MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 012 · AUGUST 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

EXPLAINER · RMF AND ATO

RMF and CMMC Are Not the Same Program. Run Them as One.

RMF authorizes a system, CMMC certifies a contractor. They ask overlapping questions in different vocabularies - and paying twice is the mistake.

BY **MACTECH SOLUTIONS** READING TIME · 4 MIN RMF · CMMC · NIST-800-171 · GOVERNANCE

A contractor running both an RMF authorization and a CMMC Level 2 program will usually be told, by someone with a stake in the answer, that these are entirely separate obligations requiring separate teams, separate evidence, and separate budgets. That advice is half right, and the half that is wrong is expensive.

FIELD COPY
ISSUE Nº 012
RMF

They are separate obligations. They are not separate work.

Why the "totally different" framing survives

The frameworks answer different questions about different things. RMF authorizes a *system* to operate on a government network - it produces an Authorization to Operate, granted by a named official who accepts residual risk on behalf of the government. CMMC certifies an *organization* as fit to handle CUI under a contract clause.

Different scope, different artifact, different decision-maker. So the framing is not fabricated. It is just incomplete, because it stops at the artifacts and never reaches the evidence underneath them.

Both frameworks want to know: what is in the boundary, who can access it, how is access proven, what is logged, how long are logs kept, what happens when something goes wrong, and how do you know any of this is still true next quarter. An access control implementation does not become a different implementation because one auditor calls it AC-2 and another calls it 3.1.1.

4 min

READING TIME, NO PAYWALL, NO POP-UPS

◆ DIFFERENT CATALOGS, COMMON ANCESTRY

RMF selects controls from **NIST SP 800-53**. CMMC Level 2 aligns to **NIST SP 800-171**, which was derived from 800-53 for non-federal systems. The lineage is why the overlap is real - and why the wording never quite matches.

Where the overlap is real, and where it is not

The overlap concentrates in the technical control families - access control, audit and accountability, identification and authentication, system and communications protection. A well-run boundary generates one set of evidence that answers both catalogs, provided the evidence was collected against the system rather than against a questionnaire.

The overlap thins out at both ends. RMF's categorization step has no CMMC equivalent - nothing in Level 2 asks you to reason about impact levels the way FIPS 199 does. And CMMC's assessment mechanics have no RMF equivalent: a C3PAO is not an authorizing official, and certification is not risk acceptance.

So the honest picture is a wide middle and two distinct ends. The middle is where duplicated effort lives, and it is most of the work.

The failure that costs the money

Here is what actually goes wrong, and it is organizational rather than technical.

The RMF effort gets staffed by the program team, because it is tied to a contract deliverable. The CMMC effort gets staffed by IT or a compliance hire, because it is tied to corporate eligibility. Each builds its own control narratives, its own evidence collection, its own review cadence. Neither knows the other exists in any operational sense.

Two years later the company is maintaining two descriptions of the same network, and they have drifted. That drift is not merely wasteful - it is a finding waiting to happen, because an assessor who obtains both documents now has a contradiction to ask about, and "those were written by different teams" is not an answer that improves the situation.

The fix is unglamorous: one control inventory, mapped to both catalogs, maintained once. The narratives that feed an SSP and the narratives that feed a Security Plan for authorization come out of the same source of truth. Where the catalogs genuinely diverge, you write the delta - not a second document.

What to do if you are already running both

Do not restructure the programs. Restructure the evidence.

Start with the control families where both catalogs apply to the same systems, and pick the one that is currently maintained best. That becomes the source. Map it outward to both catalogs and retire the duplicate narrative - not by deleting it, but by making it a reference. Then work outward family by family, in order of how much the two versions currently disagree, because the disagreements are the findings.

You will not finish this in a quarter, and you should not try. What you should get in a quarter is the mapping itself, which is the artifact that makes every subsequent decision cheaper and which almost nobody has.

MacTech runs RMF support and CMMC readiness out of one governance practice for exactly this reason - the second engagement is substantially cheaper than the first, and it should be. Talk to a director if you are currently paying for both twice. ◆◆